SELÇUK ÜNİVERSİTESİ

Teknoloji Fakültesi

Bilgisayar Mühendisliği Bölümü

Bilgisayar Mühendisliği Uygulamaları

ÇAP / YDP Takip Sistemi

Güvenlik Testleri ve Tasarım Açıklaması

OWASP Top 10 eşlemesi, otomatik güvenlik testleri,
OWASP ZAP taraması ve mimari açıklama

Hazırlayan	**Hamza Çeliktürk**
Öğrenci No	**213301056**
Tarih	**Ekim 2026**

Konya, 2026

İçindekiler

1. Amaç ve kapsam
2. Sistem mimarisi ve tasarım kararları
3. Tehdit modeli
4. Güvenlik önlemleri: OWASP Top 10 (2021) eşlemesi
5. Otomatik testler
6. OWASP ZAP güvenlik taraması
7. Taramalarda bulunan ve düzeltilen sorunlar
8. Yayına alma kontrol listesi
9. Sonuç

1. Amaç ve kapsam

Bu belge, ÇAP / YDP Takip Sisteminin **güvenlik testlerini** ve **tasarımını** açıklar. Proje ve Tasarım Raporu'nun tamamlayıcısıdır. O rapor sistemin neyi yapacağını anlatır; bu belge ise geliştirmenin 1–8. adımlarında kurulan yapının nasıl korunduğunu, nasıl test edildiğini ve testlerin sonuçlarını belgeler.

> **Etik ve kapsam sınırı.** Ders koordinatörünün şartı gereği sistemde yalnızca **sentetik (uydurma) veri** kullanıldı. Sızma testleri ve otomatik taramalar **yalnızca bu projenin kendi uygulaması üzerinde** ve geliştiricinin kendi test ortamında (yerel adres 127.0.0.1, ayrı bir demo veritabanı) yapıldı. Üniversitenin hiçbir sistemine (OBİS, e-posta, web sitesi) tarama veya istek gönderilmedi.

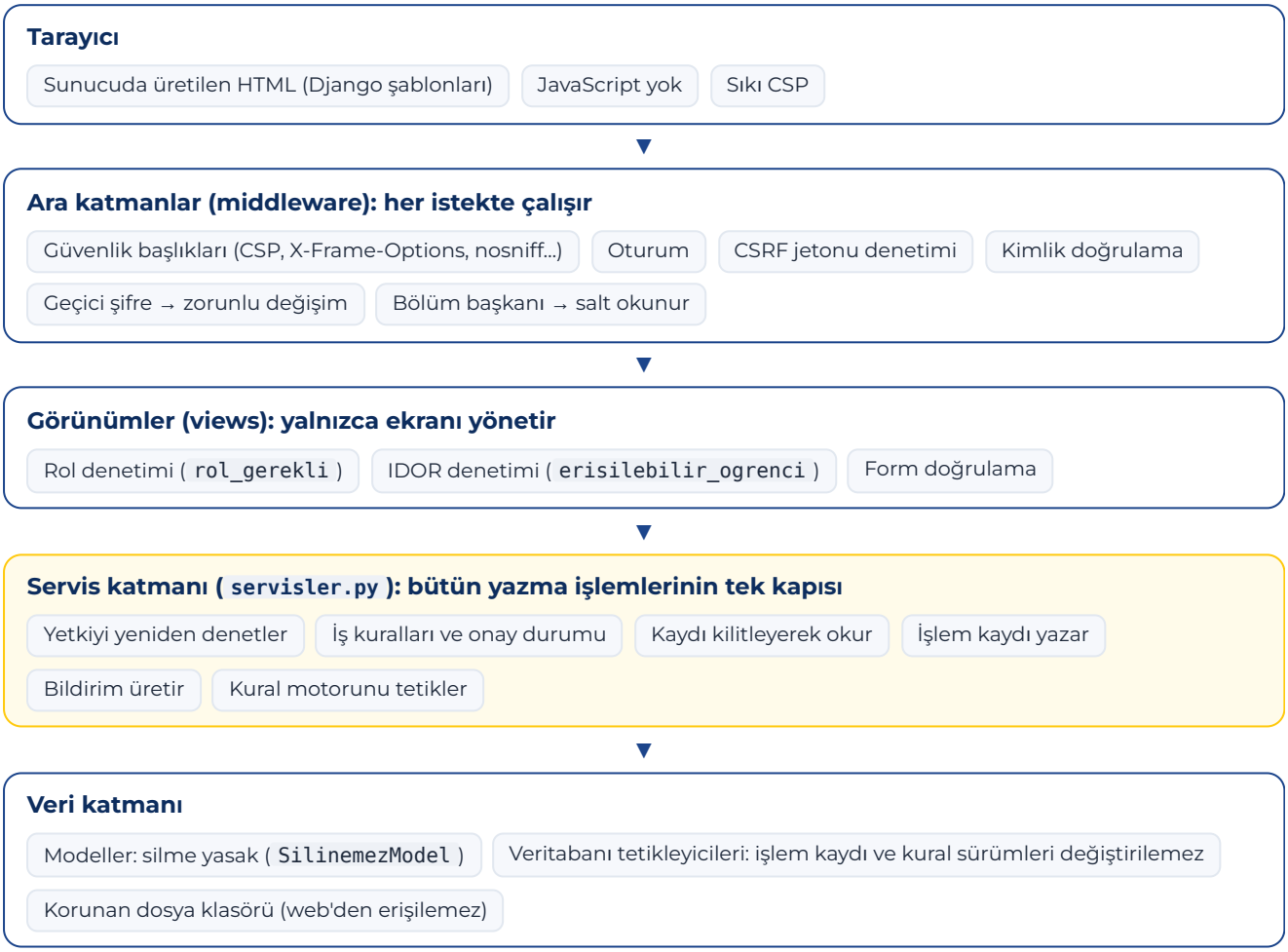
Test ortamı

Bileşen	Sürüm / ayar
Uygulama	Django 5.2.18, Python 3.13
Veritabanı	SQLite (WAL kipi; PostgreSQL desteği hazır)
Tarama aracı	OWASP ZAP 2.16.1, Automation Framework (komut satırı)
Uygulama kipi	`DEBUG=0` , ayrı demo veritabanı (`demo.sqlite3`), 9 sentetik öğrenci
Otomatik test	Django test çatısı, 191 test, ayrı test veritabanında

2. Sistem mimarisi ve tasarım kararları

2.1 Katmanlı yapı

Bir isteğin izlediği yol aşağıda gösterilmiştir. Güvenlik denetimleri tek bir yerde değil, **birden çok katmanda** yapılır (derinlemesine savunma). Bir katmanda bir kontrol unutulsa bile alttaki katman isteği durdurur.



Ekrandan giriş, CSV ile aktarım ve demo verisi aynı servis fonksiyonlarını çağırır. Böylece yetki, iş kuralları ve işlem kaydı hiçbir yoldan atlanamaz.

2.2 Uygulamalar

Uygulama	Sorumluluk
`accounts`	Kullanıcı ve roller, giriş, kaba kuvvet kilidi, şifre politikası, hesap yönetimi
`denetim`	İşlem kaydı: kim, ne zaman, neyi, eski ve yeni değer, IP. Değiştirilemez ve silinemez.
`ogrenciler`	Öğrenci, program kaydı (ÇAP/YDP), dönem kaydı, ana dal bilgisi, kurul kararları
`dersler`	Ders kataloğu, protokol, öğrencinin ders listesi, deneme ve not; onay mekanizması
`belgeler`	Güvenli dosya yükleme, sürümleme, belge isteği, yetkili indirme
`kurallar`	Sürümlü kural ayarları, kural motoru, uyarılar

`mesajlar`	Öğrenci–koordinatör yazışması (ekli), sistem içi bildirimler
`aktarim`	CSV ile geçmiş veri aktarımı (önizleme, sonra ya hep ya hiç uygulama); OBİS'e hazır sütun eşlemesi
`ortak`	Silinmezlik ve onaylı kayıt temel sınıfları, güvenlik başlıkları ara katmanı

2.3 Temel tasarım kararları

Karar	Gerekçe
Hiçbir kayıt silinmez	Akademik kayıtlarda geçmişin izlenebilmesi gerekir. Hatalı kayıt gerekçeyle "iptal" edilir, reddedilen kayıt "reddedildi" olarak kalır. Silme denemesi kod seviyesinde engellenir.
Onay mekanizması	Öğrencinin girdiği ders, dönem kaydı, not ve belge "onay bekliyor" durumunda başlar ve koordinatör onaylayana kadar hesaplara girmez. Onaylanan kayıt kilitlenir.
Sürümlü kural ayarları	Yönerge eşikleri (2,72; iki dönem; 6 ders/30 AKTS…) koda gömülü değildir. Yönerge değişince yeni sürüm açılır; eski sürüm ve onunla yapılmış değerlendirmeler değişmez.
Donmuş değerlendirme	Her kural değerlendirmesi, kullandığı sürümü ve o anki girdi verisini saklar. Geçmişte neden uyarı verildiği her zaman açıklanabilir.
Uyarı karar değildir	Sistem kayıt silme veya mezuniyet kararı vermez; şartın oluştuğunu bildirir. Karar, kurulun karar yazısı dayanak gösterilerek koordinatör tarafından işlenir.
Ya hep ya hiç aktarım	CSV dosyası önce veritabanına yazmadan denenir (önizleme). Bir satır bile hatalıysa hiçbir satır yazılmaz; yarım kalmış aktarım olmaz.
JavaScript'siz arayüz	Sayfalar sunucuda üretilir. Bu sayede İçerik Güvenlik Politikası (CSP) hiçbir betiğe izin vermeyecek kadar sıkı tutulabilir; olası bir XSS açığı tarayıcıda çalışamaz.

3. Tehdit modeli

3.1 Korunan varlıklar

Varlık	Neden önemli	Hedef
Öğrenci kişisel bilgileri ve notlar	Kişisel veri (KVKK); başkası görmemeli	Gizlilik
Ders, not ve onay durumları	Yönerge kararlarının dayanağı; yetkisiz değişirse yanlış karar çıkar	Bütünlük
Yüklenen belgeler (transkript, kurul kararı)	Resmî belge; zararlı dosya yayılmamalı	Gizlilik, bütünlük
İşlem kaydı	Kimin ne yaptığının kanıtı; silinir veya değişirse hesap sorulamaz	Bütünlük, inkâr edilemezlik
Kural sürümleri ve kurul kararları	Uyarıların ve sonuçların yasal dayanağı	Bütünlük

3.2 Tehdit aktörleri ve senaryolar

Aktör	Olası saldırı	Önlem (bölüm 4)
Meraklı/kötü niyetli öğrenci	Adresteki numarayı değiştirerek başkasının notunu görmek (IDOR); kendi notunu onaylı göndermek (toplu atama); onaylanmış kaydı değiştirmek	A01
Dışarıdan saldırgan	Şifre deneme (kaba kuvvet); zararlı dosya yükleme; XSS ile oturum çalma; CSRF ile koordinatöre işlem yaptırma	A03, A04, A07
Yetkisini aşan kullanıcı	Bölüm başkanının veri değiştirmesi; koordinatörün iz bırakmadan kayıt silmesi	A01, A08, A09
Hatalı/eksik veri	Bozuk CSV; Excel formülü içeren hücre (CSV enjeksiyonu); ikinci kez aktarılan dosya	A03, A08

3.3 Güven sınırları

- **Tarayıcı ↔ sunucu:** Kullanıcıdan gelen hiçbir değere (adres, form alanı, dosya adı, CSV hücresi) güvenilmez. Hepsi sunucuda doğrulanır.
- **Rol sınırı:** Öğrenci ↔ koordinatör ↔ bölüm başkanı. Her ekran ve her servis rolü ayrı ayrı denetler.
- **Dosya sınırı:** Yüklenen dosyalar web köküne konmaz; yalnızca yetki denetimi yapan indirme görünümü ile, ek olarak ve betik çalıştıramayacak başlıklarla verilir.

4. Güvenlik önlemleri: OWASP Top 10 (2021) eşlemesi

Risk	Önlem	Doğrulama
A01 Erişim kontrolü	Rol denetimi görünümde ve serviste (iki kat). `erisilebilir_ogrenci`: öğrenci başka numarayı açarsa 403, başkasının kayıt kimliği 404. Bölüm başkanı için ara katmanda POST yasağı. Öğrenci formdan onay durumu/not gönderse de dikkate alınmaz.	Rol matrisi, IDOR, toplu atama testleri; ZAP
A02 Kriptografik hatalar	Şifreler PBKDF2-SHA256 (Django) ile özetlenir, düz metin saklanmaz. Geçici şifreler `secrets` ile üretilir ve yalnızca bir kez gösterilir. Yayında HTTPS, güvenli çerez ve HSTS (`CAPTAKIP_HTTPS=1`). Belgelerin SHA-256 özeti saklanır.	`check --deploy`
A03 Enjeksiyon	SQL: yalnızca ORM (parametreli sorgu), elle SQL yok. XSS: şablonlarda otomatik kaçış, `|safe` kullanıcı verisinde yok, sıkı CSP. CSV: `= + - @` ile başlayan hücre reddedilir. Dosya adı: dizin atlama temizlenir, diskte rastgele ad kullanılır.	XSS, SQLi, dizin atlama testleri; ZAP aktif tarama
A04 Güvensiz tasarım	Onay mekanizması; ya hep ya hiç aktarım; silinmezlik; uyarı ile kararın ayrılması; değiştiren işlemler yalnızca POST ve CSRF jetonuyla.	CSRF ve yöntem testleri
A05 Yanlış yapılandırma	Güvenlik başlıkları: CSP, X-Frame-Options DENY, nosniff, Referrer-Policy, COOP, CORP, Permissions-Policy. Oturum ve CSRF çerezleri HttpOnly + SameSite=Lax. Kişisel veri içeren sayfalar önbelleğe alınmaz. `DEBUG=0` iken sade hata sayfaları.	Başlık testleri; ZAP pasif tarama
A06 Eski bileşenler	Az bağımlılık (yalnızca Django). Sürüm `requirements.txt` ile sabit; güncel 5.2 LTS.	Sürüm kontrolü
A07 Kimlik doğrulama	5 hatalı denemede 15 dakika kilit; hata mesajı kullanıcının var olup olmadığını sızdırmaz. Şifre politikası: en az 10 karakter, yaygın veya yalnızca rakamdan oluşan şifre ve kullanıcı adına benzeyen şifre yasak. İlk girişte şifre değişimi zorunlu. 2 saat hareketsizlikte oturum düşer. Girişten sonra açık yönlendirme yok.	Kilit, açık yönlendirme, zayıf şifre testleri
A08 Yazılım ve veri bütünlüğü	İşlem kaydı, kural sürümü ve değerlendirmeler veritabanı tetikleyicileriyle değiştirilemez. Aynı CSV dosyası (SHA-256) ikinci kez uygulanamaz. Yüklenen dosyalarda gerçek içerik denetimi yapılır; JavaScript veya gömülü dosya içeren PDF reddedilir.	Doğrudan SQL ile değişiklik testleri
A09 Kayıt ve izleme	Her yazma işlemi eski ve yeni değeri, yapanı ve IP'siyle kaydedilir. Başarılı ve başarısız girişler ayrıca tutulur. Sunucu hataları ayrıntısıyla günlüğe yazılır.	İşlem kaydı testleri
A10 SSRF	Sistem kullanıcı tarafından verilen bir adrese istek göndermez. Bildirim bağlantıları yalnızca site içi yola yönlenir.	Açık yönlendirme testi

Dosya yükleme güvenliği

- Uzantı beyaz listesi (PDF, PNG, JPEG) ve **dosyanın gerçek içeriğinin** denetimi (magic bytes). Uzantısı .pdf olup içi farklı olan dosya reddedilir.

- Bütünlük denetimi (PDF `%%EOF`, PNG `IEND`, JPEG `FFD9`); JavaScript veya gömülü dosya içeren PDF reddedilir; boyut sınırı 10 MB.
- Diskte rastgele ad; indirmede `Content-Disposition: attachment`, `nosniff` ve `CSP: sandbox`.

5. Otomatik testler

Projede toplam **191 otomatik test** vardır ve hepsi geçmektedir. Testler her çalıştırmada boş bir test veritabanı kurar, yalnızca sentetik veriyle çalışır ve gerçek dosya arşivine dokunmaz. Proje klasöründeki `testleri_calistir.bat` ile tek tıkla çalıştırılabilir.

Test dosyası	Kapsam	Test
accounts/tests.py	Giriş, kaba kuvvet kilidi, roller, hesap yönetimi, işlem kaydının değiştirilemezliği	17
accounts/tests_guvenlik.py	Güvenlik test paketi (OWASP Top 10)	24
ogrenciler/tests.py	Öğrenci kaydı, protokol, öğrenci kartı, IDOR	22
dersler/tests.py	Onay mekanizması: seçim, deneme, not, red, iptal, düzeltme	28
belgeler/tests.py	Güvenli dosya yükleme, sürümleme, belge isteği	31
kurallar/tests.py	Kural sürümleri, kural motoru, uyarılar, kurul kararları	29
mesajlar/tests.py	Mesajlaşma, ekler, bildirimler	23
aktarim/tests.py	CSV aktarımı: önizleme, ya hep ya hiç, formül enjeksiyonu	17
Toplam		**191**

5.1 Güvenlik test paketi (`accounts/tests_guvenlik.py`)

Sızma testinde elle yapılacak saldırıların otomatik hâlidir. Her kod değişikliğinden sonra yeniden çalıştırılabildiği için bir açığın sonradan geri gelmesini önler.

Grup	Ne deneniyor	Beklenen
Erişim kontrolü	Giriş yapmadan 15 sayfa; öğrenci olarak yönetim sayfaları; bölüm başkanı olarak değişiklik	Girişe yönlendirme / 403
IDOR	Öğrencinin başka öğrencinin kartını, durumunu, belgelerini, mesajlarını açması; onun adına mesaj, ders, dönem kaydı ve belge göndermesi; başkasının belgesini indirmesi	403 / 404, kayıt oluşmaz
Toplu atama	Öğrencinin forma "onaylandı", "AA", "geçti" alanlarını eklemesi	Kayıt onay bekler, not yok
Kalıcı XSS	Mesaj, koordinatör notu, öğrenci adı ve dosya adında `<script>` ve `onerror` yükleri	Kaçışlı gösterim
SQL enjeksiyonu	Arama kutusu ve adreste `' OR '1'='1` , `DROP TABLE` yükleri	Filtre aşılmaz, tablo yerinde
CSRF ve HTTP yöntemi	Jetonsuz POST; değiştiren işlemleri GET ile çağırma	403 / 405
Yapılandırma	Güvenlik başlıkları, çerez bayrakları, satır içi betik/stil yokluğu, DEBUG kapalıyken hata sayfası	Başlıklar var, iç bilgi sızmaz

Kimlik doğrulama	Girişte ve bildirimde dış siteye yönlendirme; başkasının bildirimini açma; zayıf şifreler; kendi şifresini sıfırlama	Engellenir
Yönlendirme (ZAP bulgusu)	Onay ve şifre sıfırlama işlemlerinde "geri dön" adresine dış site, `//site` ve anlamsız metin gönderme	Varsayılan sayfaya dönülür, 500 yok

Diğer test dosyalarında da güvenlikle ilgili testler bulunur: kaba kuvvet kilidi, işlem kaydının doğrudan SQL ile bile değiştirilememesi, sahte uzantılı ve JavaScript içeren PDF'lerin reddi, CSV formül enjeksiyonu, kural sürümlerinin değiştirilemezliği.

6. OWASP ZAP güvenlik taraması

6.1 Yöntem

OWASP ZAP, web uygulamalarına gerçek bir saldırgan gibi istek gönderen açık kaynaklı bir güvenlik tarayıcısıdır. Taramalar ZAP'ın Automation Framework'ü ile komut satırından, tekrarlanabilir bir plan dosyasıyla yapıldı:

1. Uygulama ayrı demo veritabanıyla ve `DEBUG=0` kipinde başlatıldı; 9 sentetik öğrenci, belge, mesaj ve aktarım kaydı yüklendi.
2. **Anonim tarama:** giriş yapmamış bir saldırganın görebildiği yüzey (örümcek + pasif tarama).
3. **Koordinatör oturumuyla tarama:** en geniş yetkili kullanıcının oturumu ZAP'a verildi. Örümcek bütün sayfaları ve formları gezdi, ardından **aktif tarama** her form alanına ve adres parametresine SQL enjeksiyonu, XSS, komut enjeksiyonu, dizin atlama gibi saldırı yüklerini gönderdi. Bu taramada uygulamaya yaklaşık **68.000** istek gönderildi.
4. Çıkış ve şifre değiştirme sayfaları, oturumun tarama sırasında kapanmaması için hariç tutuldu.

6.2 Anonim tarama sonucu

0	0	2	3
Yüksek	Orta	Düşük	Bilgi

Risk	Bulgu	Durum
Düşük	**Sunucu başlığında sürüm bilgisi** Server Leaks Version Information via "Server" HTTP Response Header Field · 7 yer	**Yalnızca geliştirme sunucusu** "WSGIServer/0.2 CPython/3.13" başlığını Django'nun geliştirme sunucusu ekler, uygulama değil. Yayında Nginx'te server_tokens off ile gizlenir.
Düşük	**Statik CSS dosyasında nosniff başlığı yok** X-Content-Type-Options Header Missing · 1 yer	**Yalnızca geliştirme sunucusu** Statik dosyaları geliştirme sunucusu, ara katmanlardan geçirmeden verir. Uygulamanın bütün sayfalarında başlık var (testle doğrulandı). Yayında Nginx statik dosyalara da ekler.
Bilgi	**Giriş isteği tanımlandı** Authentication Request Identified · 1 yer	**Bilgi, açık değil** ZAP giriş formunu buldu. Giriş formu CSRF jetonu ve kaba kuvvet kilidiyle korunuyor.
Bilgi	**Oturum çerezi tanımlandı** Session Management Response Identified · 3 yer	**Bilgi, açık değil** ZAP oturum çerezini buldu. Çerez HttpOnly ve SameSite=Lax; hareketsizlikte 2 saatte düşer.
Bilgi	**Kullanıcı girdisi HTML özniteliğinde (olası XSS)** User Controllable HTML Element Attribute (Potential XSS) · 2 yer	**Bilgi, açık değil** Arama kutusuna yazılan değer, kutunun içinde yeniden gösteriliyor. Değer kaçışlı yazılıyor; aktif taramadaki XSS saldırıları ve kalıcı XSS testleri başarısız oldu.

6.3 Koordinatör oturumuyla aktif tarama sonucu

0	0	2	2
Yüksek	Orta	Düşük	Bilgi

Risk	Bulgu	Durum
Düşük	**Sunucu başlığında sürüm bilgisi** Server Leaks Version Information via "Server" HTTP Response Header Field · 539 yer	**Yalnızca geliştirme sunucusu** "WSGIServer/0.2 CPython/3.13" başlığını Django'nun geliştirme sunucusu ekler, uygulama değil. Yayında Nginx'te server_tokens off ile gizlenir.
Düşük	**Statik CSS dosyasında nosniff başlığı yok** X-Content-Type-Options Header Missing · 1 yer	**Yalnızca geliştirme sunucusu** Statik dosyaları geliştirme sunucusu, ara katmanlardan geçirmeden verir. Uygulamanın bütün sayfalarında başlık var (testle doğrulandı). Yayında Nginx statik dosyalara da ekler.
Bilgi	**Oturum çerezi tanımlandı** Session Management Response Identified · 582 yer	**Bilgi, açık değil** ZAP oturum çerezini buldu. Çerez HttpOnly ve SameSite=Lax; hareketsizlikte 2 saatte düşer.
Bilgi	**Kullanıcı girdisi HTML özniteliğinde (olası XSS)** User Controllable HTML Element Attribute (Potential XSS) · 160 yer	**Bilgi, açık değil** Arama kutusuna yazılan değer, kutunun içinde yeniden gösteriliyor. Değer kaçışlı yazılıyor; aktif taramadaki XSS saldırıları ve kalıcı XSS testleri başarısız oldu.

Özet: Aktif taramada **yüksek ve orta riskli açık bulunmadı.** SQL enjeksiyonu, XSS, komut enjeksiyonu, dizin atlama ve CSRF denemelerinin hiçbiri başarılı olmadı. Kalan düşük seviyeli bulgular, Django'nun yalnızca geliştirme için kullanılan sunucusundan kaynaklanır; yayın ortamında kullanılacak web sunucusu ayarlarıyla giderilir (bölüm 8). ZAP'ın ayrıntılı HTML raporları proje klasöründe `docs/guvenlik/` altındadır.

7. Taramalarda bulunan ve düzeltilen sorunlar

Testler ve tarama sırasında aşağıdaki sorunlar bulundu ve düzeltildi. Her düzeltmeden sonra bütün testler yeniden çalıştırıldı.

#	Bulgu	Yapılan düzeltme
1	**CSRF çerezinde HttpOnly yok** ZAP, anonim tarama · Düşük	Sitede JavaScript olmadığı için CSRF çerezinin betikten okunmasına gerek yok. `CSRF_COOKIE_HTTPONLY = True` yapıldı. İkinci taramada bulgu kalktı.
2	**Eşzamanlı yazmada sunucu hatası (500)** ZAP, aktif tarama · Kullanılabilirlik	İlk taramada aynı saniyede gönderilen 4 yazma isteği 500 hatası verdi. O sırada hata ayrıntısı günlüğe yazılmıyordu; istekler tek tek tekrarlandığında hata oluşmadı. En olası neden SQLite'ın eşzamanlı yazmada verdiği "veritabanı kilitli" hatasıdır. Önlem olarak veritabanı WAL kipine ve `IMMEDIATE` işlem kipine alındı (yazma kilidi baştan alınır, meşgulse 20 saniyeye kadar beklenir). Ayrıca `DEBUG=0` iken de sunucu hatalarının ayrıntısı günlüğe yazılıyor. Tekrarlanan taramada 68.000 istekte **hiç 500 hatası oluşmadı**. Yayında PostgreSQL kullanılması önerilir.
3	**Koordinatör kendi şifresini "sıfırla" ile sıfırlayabiliyordu** ZAP örümceği formu gönderince oturum düştü	Güvenlik açığı değil ama hatalı tıklamada koordinatör kendini sistemden atıyordu. Kendi hesabı için "Şifre sıfırla" ve "Pasife al" düğmeleri kaldırıldı, servis de engelliyor. Bunun için yeni bir test eklendi.
4	**"Geri dön" parametresinde sunucu hatası** ZAP, aktif tarama · Kullanılabilirlik	Onay/red formlarındaki gizli `geri` alanına ZAP rastgele metin yazınca Django bu metni sayfa adı sandı ve 8 istekte 500 hatası oluştu. Bu hatalar 2. maddede eklenen günlük ayarı sayesinde ayrıntısıyla görüldü. Artık yalnızca `/` ile başlayan site içi yollar kabul ediliyor (`ortak/guvenlik.py` → `guvenli_yonlendir`).
5	**Açık yönlendirme (open redirect)** Kod incelemesi (4. maddedeki kalıp aranırken) · Düşük	Hesaplar sayfasındaki "Şifre sıfırla" işlemi `geri` değerini denetlemeden yönlendiriyordu: `geri=https://kotu-site…` ile kullanıcı dış siteye gönderilebilirdi. Yalnızca koordinatörün kullanabildiği ve CSRF jetonu gerektirdiği için istismarı zordu. Aynı güvenli yönlendirme fonksiyonuna geçirildi; iki madde için testler eklendi.
6	**Sayfalarda satır içi stil** CSP incelemesi	İlerleme çubuklarındaki `style="width:…"` kaldırıldı, yerine HTML `<progress>` öğesi kullanıldı. Böylece CSP `'unsafe-inline'` olmadan, en sıkı hâliyle uygulanabildi.
7	**Eksik güvenlik başlıkları** OWASP Secure Headers listesi	Yeni ara katman (`ortak/guvenlik.py`): Content-Security-Policy, Permissions-Policy, Cross-Origin-Resource-Policy ve oturum açık sayfalar için `Cache-Control: no-store` eklendi.
8	**Hata sayfaları ve günlük** Yapılandırma incelemesi	Özel 404 ve 500 sayfaları eklendi. `DEBUG=0` iken adres listesi, ayarlar veya kod parçası gösterilmez (testle doğrulandı). Kullanıcı sade bir sayfa görürken hatanın ayrıntısı sunucu günlüğüne yazılır.

8. Yayına alma kontrol listesi

Proje şu an geliştirme ve demo ortamında çalışır. Sunucuya kurulurken aşağıdaki adımlar uygulanmalıdır. Django'nun yayın denetimi (`manage.py check --deploy`) bu ayarlarla çalıştırıldığında yalnızca HSTS preload uyarısı kalır. Preload alan adı düzeyinde ve geri alınması zor bir karar olduğu için bilerek açılmamıştır.

Adım	Nasıl
Gizli anahtar	`CAPTAKIP_SECRET_KEY` ortam değişkeni (rastgele, en az 50 karakter); kodda saklanmaz
Hata ayıklama kapalı	`CAPTAKIP_DEBUG=0`
HTTPS	`CAPTAKIP_HTTPS=1` : güvenli çerezler, HTTP→HTTPS yönlendirme, HSTS
Alan adı	`CAPTAKIP_ALLOWED_HOSTS`
Web sunucusu	Gunicorn + Nginx. Nginx statik dosyalarda da `nosniff` ekler ve `Server` başlığındaki sürüm bilgisini gizler (ZAP'ın düşük bulguları).
Veritabanı	`CAPTAKIP_DB=postgres` ; işlem kaydı tetikleyicileri PostgreSQL için de hazır
Yedekleme	Veritabanı ve `korunan_dosyalar` klasörünün düzenli, şifreli yedeği
Kullanıcılar	Gerçek veriye geçmeden önce KVKK aydınlatma metni ve bölüm onayı

9. Sonuç

ÇAP / YDP Takip Sistemi, güvenliği sonradan eklenen bir özellik olarak değil, tasarımın parçası olarak ele alır. Yetki denetimi birden çok katmanda yapılır, bütün yazma işlemleri tek bir servis katmanından geçer, kayıtlar silinmez ve her değişiklik değiştirilemez bir işlem kaydına yazılır.

191 otomatik test ve iki OWASP ZAP taraması sonucunda yüksek veya orta riskli açık bulunmamıştır. Bulunan düşük seviyeli sorunlar düzeltilmiş; kalanlar yalnızca geliştirme sunucusuna özgüdür ve yayın ortamı ayarlarıyla giderilecektir. Bütün testler yalnızca sentetik veriyle ve projenin kendi test ortamında yapılmıştır.